Middle Technical University

LECTURE 1: CYBERSECURITY GOVERNANCE

Foundations of Information Security, Protection Architecture & Enterprise Governance

Course Module: CSTE4104	Lecturer: Dr. Ammar Yahya Daeef
Topic: Governance, CIA/DAD, AAA & Controls	Target Audience: 4th stage Students

Lecture roadmap

- Security fundamentals and continuous improvement
- The five pillars of information security and the CIA Triad
- DAD, authenticity, nonrepudiation, and AAA services
- Protection mechanisms and security boundaries
- Security governance

1. Introduction

Security helps an organization continue to exist and operate despite attempts to steal data or compromise its physical and logical assets. It is a business management responsibility, not merely an IT concern. IT/IS consists of the hardware and software that support business operations, while security protects their reliable and secure operation and supports the organization's mission, goals, and objectives.

Organizations should adopt a security framework as a starting point and continuously evaluate and test their defenses. Three common evaluation methods are used: **risk assessment**, which identifies assets, threats, and vulnerabilities to determine risk; **vulnerability assessment**, which uses automated tools to find known weaknesses; and **penetration testing**, which uses trusted testers to stress-test defenses and discover issues before adversaries exploit them.

Evaluation Methodology	Primary Objective	Core Mechanism & Execution
Risk Assessment	Identify assets, threats, and vulnerabilities to calculate overall exposure.	Evaluates impact vs. likelihood; establishes risk mitigation priorities.
Vulnerability Assessment	Identify known software, hardware, and configuration weaknesses.	Employs automated scanning tools and baselining across networks and hosts.
Penetration Testing	Stress-test active defenses against simulated real-world adversarial attacks.	Conducted by ethical/trusted testers to find exploitable zero-days and logic gaps.

Organizations have limited budgets and must allocate resources wisely. Security controls should be selected to provide the greatest protection at the lowest reasonable cost, while meeting the organization's security needs.

Security decisions should comply with applicable laws and be supported by appropriate evidence. This helps an organization defend its actions in court, respond to security breaches, and reduce the risk of fines, penalties, or negligence claims.

Security is an ongoing process, not a project that can ever be considered complete. Technology, user behavior, vulnerabilities, and attack methods continually change. Therefore, organizations must regularly reassess their security infrastructure and improve their defenses because protections that were sufficient yesterday may not be sufficient tomorrow.

2. Understand and Apply Security Concepts

The Five Pillars of Information Security: confidentiality, integrity, availability, authenticity, and nonrepudiation. The first three form the CIA Triad, which represents the primary goals of information security. Security controls, vulnerabilities, and risks are evaluated according to how they affect these principles.



2.1 Confidentiality

Confidentiality ensures that information is disclosed only to authorized individuals or systems. Unauthorized disclosure may result from deliberate attacks, human errors, poor security policies, or incorrectly configured controls. Common protections include encryption, access control, strong authentication, data classification, and employee training. Important related concepts include sensitivity (potential harm from disclosure),

discretion (controlling disclosure), concealment and secrecy (hiding or preventing disclosure), privacy (protecting personal information), seclusion (storing information in a restricted location), and isolation (keeping information separate).

2.2 Integrity

Integrity protects the accuracy, correctness, and reliability of information by preventing unauthorized modifications and minimizing mistakes made by authorized users. It also ensures that data remains consistent and reflects reality. Threats include viruses, unauthorized access, software errors, malicious modifications, logic bombs, and backdoors. Common protections include access controls, strong authentication, intrusion detection, hash verification, input validation, and employee training. Key integrity concepts include accuracy, truthfulness, validity, accountability, responsibility, completeness, and comprehensiveness.

2.3 Availability

Availability ensures that authorized users can access information and systems when needed, without unacceptable interruption. Threats include hardware failures, software errors, environmental problems, power loss, denial-of-service (DoS) attacks, and communication interruptions. Protection measures include performance monitoring, effective access controls, firewalls, redundant systems, reliable and tested backups, and fault tolerance. Business continuity planning (BCP) helps maintain critical services and eliminate single points of failure. Availability also involves three important concepts: usability (ease of use), accessibility (the ability of different users to interact with resources), and timeliness (providing access or responses within a reasonable time).

QUICK MEMORY & RECALL MATRIX (THE CIA TRIAD)
• Confidentiality: "Who can see or read the information?" (Restricting view)
• Integrity: "Is the information accurate, valid, and unmodified?" (Preventing tampering)
• Availability: "Can authorized users access systems and data on demand?" (Ensuring uptime)

2.4 DAD, Overprotection, Authenticity, Nonrepudiation, and AAA Services

Beyond the CIA Triad, designing effective security policies and solutions requires evaluating additional principles such as the DAD Triad, the hazards of overprotection, authenticity, nonrepudiation, and comprehensive AAA services. The DAD Triad serves as the direct opposite and failure state of the CIA Triad, comprising disclosure (unauthorized access violating confidentiality), alteration (malicious or accidental changes violating integrity), and destruction/DoS (resources being damaged or made inaccessible, violating availability). Additionally, balancing security is critical because overprotecting confidentiality or

integrity can inadvertently restrict availability, whereas overproviding availability can destroy confidentiality and integrity. Other pillars include authenticity, which verifies that data is genuine and originates from its claimed origin, and nonrepudiation, which ensures that a subject cannot deny performing an action, supported through mechanisms like identification, authentication, authorization, auditing, accounting, digital certificates, and transaction logs. Finally, AAA services provide a foundational security mechanism spanning five operational elements that must be fully implemented to avoid structural vulnerabilities.

The Five Elements of AAA Services

AAA Element	Operational Definition	Implementation Mechanism
1. Identification	Claiming an identity.	Usernames, smart cards, tokens, biometric identifiers.
2. Authentication	Proving the claimed identity.	Passwords, PINs, OTP tokens, cryptographic certificates, biometric match.
3. Authorization	Granting specific permissions.	Role-Based Access Control (RBAC), Attribute-Based Access Control (ABAC), ACLs.
4. Auditing	Programmatically recording activity.	System event logs, access logs, intrusion logs (active logging vs passive monitoring).
5. Accounting (Accountability)	Reviewing logs for compliance & holding subjects legally liable.	Log aggregation (SIEM), compliance reviews, forensic investigations, nonrepudiation.



3. Protection Mechanisms

3.1 Defense in Depth

Protection mechanisms provide the structural integrity required to enforce security policies and safeguard systems against internal and external flaws. One of the most critical architectural strategies is defense in depth, which utilizes multiple layers of security controls to ensure that no single point of failure results in the exposure of systems or data.

- **Defense in Depth (Layering):**
  - Defense in depth relies on implementing multiple security controls in a series rather than in parallel, ensuring that an attack is linearly evaluated and mitigated by every single security checkpoint.
  - While parallel configurations are useful in distributed computing, serial configurations are narrow and deep, meaning the failure of one control does not render the entire security solution ineffective.
- **Related Architectural Terms:**
  - The text notes that terms such as levels, multilevel, layers, classifications, zones, realms, compartments, silos, segmentations, lattice structures, and protection rings are frequently used and should be understood within the context of defense in depth.
- **Defense in Breadth (Diversity of Defense):**

- Relying on security layers built from the same vendor or sharing common code is problematic because a single vulnerability can compromise multiple layers simultaneously.
- Utilizing a range of security products from varied vendors significantly reduces or avoids the risk of a single exploit breaching several layers at once

3.2 Abstraction

Abstraction serves as a vital operational principle designed to maximize efficiency by grouping similar elements into collective roles, classes, or groups that receive uniform security controls, permissions, and restrictions. Rooted in the principles of object-oriented programming (OOP), abstraction incorporates the unknown environment doctrine, which asserts that users or components do not need to understand the internal mechanics of an object, provided they know the correct syntax for sending inputs and receiving outputs. This doctrine mirrors mediated access models, where user-mode applications utilize system calls to request administrator-mode services, ensuring access requests are granted or denied based strictly on credentials rather than allowing unmediated access.

- **Simplification and Classification:** Abstraction simplifies security administration by allowing administrators to classify objects or assign roles to subjects, streamlining the application of controls by type or function.
- **Object Groups and Classes:** Security administrators can define object groups or classes linked to job roles, making privilege management much easier because adding an object to a class automatically confers its assigned rights and privileges without separate individual management.

3.3 Data Hiding

Data hiding serves as a critical security control and programming practice designed to prevent data from being discovered or accessed by placing it within a logical storage compartment that is completely invisible and unreachable to unauthorized subjects. Unlike security through obscurity, which merely relies on silence or secrecy and hopes an object remains undiscovered without implementing actual safeguards, data hiding provides real protection by isolating objects into separate security containers distinct from subjects who lack the authorization or means to access them.

- **Definition and Examples:**
  - Data hiding ensures that a subject cannot see or access data, rather than just keeping it temporarily unseen.
  - Practical implementations include protecting databases from unauthorized visitors, restricting lower-level classification subjects from accessing higher-level data, preventing applications from accessing hardware directly, and utilizing steganography.
- **Role in Multilevel Secure Systems:**
  - Data hiding is a vital characteristic in multilevel secure systems because it ensures that data existing at one security level is entirely invisible to processes running at different security levels.
  - From a security perspective, this relies on placing objects in security containers separate from those occupied by subjects who lack the need to know or the means to access them.
- **Data Hiding vs. Security Through Obscurity:**
  - Data hiding intentionally positions data so it is functionally unviewable and inaccessible to unauthorized subjects.
  - In contrast, security through obscurity is akin to digital hide and seek, where an organization hopes an object will not be discovered simply by keeping knowledge of it a secret without providing actual protection.
  - A classic example of security through obscurity occurs when a programmer releases software containing a known flaw, hoping that no one will discover the issue and exploit it.

4. Security Boundaries

A security boundary serves as the critical line of intersection between distinct areas, subnets, or environments that maintain differing security requirements or needs. Recognizing these boundaries—such as the perimeter separating a local area network (LAN) from the public Internet—is essential for establishing reliable security barriers and deploying necessary mechanisms to control the flow of information. Furthermore, security boundaries can manifest as distinctions between object classifications, where specific rules define which subjects are authorized to perform functions on designated objects.

- **Physical vs. Logical Environments:**
  - Security boundaries exist across both physical and logical domains, requiring distinct security mechanisms for each.
  - Both physical and logical security must be present for a complete structure and must be addressed separately within an organization's security policy.
- **Perimeter Definition and Legal Responsibility:**
  - Security policies must clearly define where control begins and ends in both environments.
  - Logical boundaries mark where electronic communications interface with organization-responsible devices, whereas physical perimeters—such as office walls, building

exteriors, or campus fences—frequently reflect the reach of the physical security policy and legal responsibility.

- **Control Implementation and Cost Efficiency:**
  - When translating security policies into actual controls, each environment and boundary must be evaluated separately to determine the most reasonable, cost-effective, and efficient solution.
  - All security countermeasures must be carefully weighed against the actual value of the protected objects, as deploying countermeasures that cost more than the protected assets is unwarranted.

5. Evaluate and Apply Security Governance Principles

Security governance encompasses the collection of practices dedicated to supporting, evaluating, defining, and directing an organization's security efforts, optimally executed by a board of directors or a governance committee. In smaller organizations, these responsibilities may fall to the chief executive officer (CEO) or the chief information security officer (CISO). By comparing internal security processes with insights from external sources—often brought by diverse board members from various industries. Security governance aims to continuously improve organizational defense and resilience. Furthermore, security governance is closely intertwined with corporate and IT governance, sharing interrelated goals focused on maintaining business processes, driving growth, and minimizing downtime and potential loss.

- **Governance Drivers and Compliance:**
  - Governance requirements are often imposed by legislative and regulatory compliance needs, industry guidelines, or licensing requirements.
  - All forms of governance must be assessed and verified periodically through auditing and validation, which can become complex when laws across different countries conflict.
- **Security as a Business Operation:**
  - Security must never be treated solely as a back-end IT issue; rather, it is a business operations issue and an organizational process that affects every aspect of the enterprise.
  - Using the term security governance emphasizes that security must be actively managed and governed throughout the entire organization, well beyond the boundaries of the IT department.
- **Security Frameworks:**
  - Organizations frequently adopt established security frameworks and governance guidelines—such as NIST SP 800-53 and NIST SP 800-100—to standardize and organize the otherwise complex process of implementing security governance.

- Although NIST guidance focuses heavily on government and military applications, it can be effectively adopted and adapted by commercial and private organizations as well.

6 Third-Party Governance

Third-party governance establishes a system of external oversight mandated by laws, regulations, industry standards, contractual obligations, or licensing requirements, typically involving outside investigators or auditors designated by a governing body or hired as consultants. Beyond external audits, third-party governance also entails applying stringent security oversight to external entities that an organization relies upon, such as third-party providers handling security guards, maintenance, technical support, or accounting services. Because these outsourced partners must fully comply with the primary organization's security stance, failing to enforce this oversight introduces severe risks and vulnerabilities to the enterprise.

- **Compliance Verification and Auditing Protocols:**
  - Third-party governance focuses heavily on verifying compliance with stated security objectives, regulations, requirements, and contractual obligations.
  - On-site assessments provide firsthand exposure to deployed security mechanisms.
  - Auditors conducting these reviews must follow established auditing protocols like Control Objectives for Information and Related Technologies (COBIT) while utilizing a specific checklist of requirements.
- **Open Document Exchange and Review:**
  - The assessment process requires full and open document exchange between the target organization and the governing body so that all compliance requirements and concerns are mutually understood, thereby reducing unrealistic expectations.
  - Organizations must submit security policies and self-assessment reports back to the governing body.
  - Transmitting these files transitions naturally into a detailed documentation review process.